GHOSTTOUCH

Android Overlay Attack:

Real Risk, Real Defense

Security Awareness Demo · Educational POC

THE PROBLEM

Android's Trust Gap

- Android allows apps to draw overlays over any other application
- Users cannot easily distinguish real UI from fake UI
- Sensitive flows like login and payment are vulnerable to interception

ATTACK FLOW

How It Works

01

Background

Disguised as a tap game, runs in background

02

Harvest

Game requests permissions: location, contacts, phone

03

Detect

Polls UsageStatsManager to find target app

04

Overlay

Pixel-perfect fake UI captures all input

05

Exfiltrate

Base64-encode + disguise as analytics telemetry

KEY INSIGHT

No sandbox break required

No system exploit required

Just UI deception

The attack exploits user trust, not system vulnerabilities.

LIVE DEMO

Attack in Action

1. Open GhostTouch — play tap game, grant game features
2. Grant overlay + usage stats in Control panel
3. Select 'Capture All' mode, start overlay service
4. **Open WcDonald's — fake verification overlay appears**
5. **View session: credentials + device intel + contacts + GPS**

IMPACT

What's at Stake

Credential Theft

Emails, passwords, usernames stolen in real-time

Payment Fraud

Card numbers, CVVs, expiry dates captured

Session Hijacking

Auth tokens and sessions intercepted

Brand Damage

Users blame your app, not the attacker

WHY IT WORKS

The Root Causes

01 Users inherently trust what they see on screen

02 The OS does not enforce visual authenticity

03 Overlay permission alone is enough to attack

DEFENSE

Defense Strategy

Block Obscured Touches

filterTouchesWhenObscured rejects input when any overlay is present

Detect Overlays

Scan installed apps for SYSTEM_ALERT_WINDOW permission and warn users

Harden Screens

FLAG_SECURE prevents screenshots and screen recording of sensitive views

Verify Identity

Biometric prompts render above overlays — impossible to cover

CRITICAL DEFENSE

filterTouchesWhenObscured

```
// XML attribute
android:filterTouchesWhenObscured="true"

// Or programmatic (Compose)
Modifier.pointerInteropFilter { event →
    (event.flags and FLAG_WINDOW_IS_OBSCURED) ≠ 0
}
```

Simple
One line of XML

Effective
Catches all overlay types

Often Ignored
Most apps don't use it

LIVE DEMO

Defense ON

- Attack fails — input blocked by touch filter
- Buttons don't respond when overlay is present
- Warning banner alerts the user
- **User is protected**

TRADE-OFFS

Consider the Balance

- ⚠ May impact UX — legitimate overlays (chat bubbles, accessibility) also blocked
- ⚠ Requires careful placement — apply only to critical views, not the entire app
- ⚠ Must be paired with clear UX messaging so users understand why input is blocked

RECOMMENDATION

Apply Protection To:

Login

Email, password, and OAuth forms

Payment

Card details, billing, checkout flows

Personal Data

SSN, addresses, identity forms

THE PERMISSION TRICK

It's Just a Game... Right?

User Sees...	They Grant...	We Actually Get...
Leaderboards	INTERNET	Data exfiltration + local IP
Nearby Players	FINE_LOCATION + WIFI_STATE	GPS coords, address, WiFi SSID/BSSID
Share Scores	READ_CONTACTS	Full contacts: names + phones
Do Not Disturb	READ_PHONE_STATE	Carrier, SIM, network type, phone number
Game Replays	READ_MEDIA_IMAGES	Photo & file scan
Daily Rewards	BOOT_COMPLETED	Auto-start after reboot (persistence)

DATA HARVESTED

50+ Fields — Zero Exploits

DEVICE
Manufacturer, model, brand, fingerprint, ABIs, board

LOCATION
GPS lat/long, accuracy, altitude, full address, city, country, postal code

WIFI / NETWORK
SSID, BSSID, IP address, gateway, DNS, subnet, signal, bandwidth, VPN status

CONTACTS
Total count + sample names & phone numbers from address book

CARRIER / SIM
Carrier name, SIM operator, network type (5G/LTE), phone number, country

INSTALLED APPS
Total count + flagged banking, crypto, social, 2FA and email apps

OS / SETTINGS
Android version, SDK, security patch, Android ID, ADB, developer mode, accessibility

HARDWARE
RAM, storage, battery, display size/density, screen resolution

All collected without any system exploit — just approved permissions.

CAPTURE ALL MODE

One Overlay, Everything Stolen

A fake "Account Verification" screen harvests all data at once:

Sign-in Details

Email
Password

Personal Info

Full Name
Phone Number

Payment Data

Card Number
Expiry + CVV

Even the "Skip" button captures whatever was partially entered. No escape.

DEMO INDICATOR

Spot the Overlay

Real App
No border
User sees this normally

Overlay (Attack)
Red border = overlay
Only visible in demo mode

In a real attack, the overlay has NO border — it's pixel-perfect identical.

FULL DEFENSE CHECKLIST

Protect Your Users

FOR DEVELOPERS

- ✓ filterTouchesWhenObscured on all forms
- ✓ FLAG_SECURE on sensitive screens
- ✓ Biometric gate before payments
- ✓ Overlay detection + user warning
- ✓ Focus change monitoring

FOR USERS

- ✓ Question why games need location
- ✓ Revoke unused permissions regularly
- ✓ Disable 'Display over apps' for unknowns
- ✓ Install apps only from trusted sources
- ✓ Watch for unexpected login prompts

WHAT ABOUT iOS?

Android vs iOS Security Model

Protection	iOS	Android
Overlay drawing API	Blocked at OS level	Allowed with permission
Foreground app detection	No API exists	UsageStatsManager
Background UI presentation	Suspended — no UI allowed	Services can add views
App distribution	App Store review required	Sideloading is trivial
Clipboard access	Banner since iOS 14	Silent access
Keychain / credentials	Per-app isolated Keychain	SharedPreferences weaker
Entitlements / capabilities	Declared at build time	Requested at any time

iOS makes overlay attacks impossible by design. But iOS is NOT immune to social engineering.

iOS ATTACK VECTORS

Different OS, Different Tricks

Push + WebView Phishing

Fake push notification opens an in-app WebView that mimics the target app's login. Fullscreen, no URL bar.

Custom Keyboard Keylogger

Keyboard extension with "Full Access" captures all keystrokes across every app. Disguised as a themed keyboard.

Universal Link Hijacking

Register same URL patterns as the target app. iOS may route the user to the attacker app instead.

ReplayKit Screen Capture

Games request ReplayKit for "gameplay recording". Once granted, can capture the screen even when other apps are visible.

Fake Auth Sheet

ASWebAuthenticationSession presents a system-style login sheet. URL bar shows the real domain, but content is attacker-controlled.

MDM / Enterprise Certificate

Enterprise-signed apps bypass App Store. Can install profiles that intercept network traffic. Used in targeted attacks.

THE REAL LESSON

No OS can protect users

who enter data in the wrong place.

Android
Overlay attacks exploit the permission model

iOS
Social engineering exploits user trust directly

Both
The user is always the last line of defense

If your UI can be mimicked,

your users can be tricked.

Q&A

Questions & Discussion

GHOSTTOUCH · Security Awareness Demo